FUTUREWAY
KI INSTITUT

Modul 1: KI-Grundlagen

Lektion 12: DSGVO

KI Automations Spezialist

Juli 2026

⚖️

Haftungsausschluss

> Diese Präsentation dient ausschließlich zu Informations- und Bildungszwecken. Die hier dargestellten Inhalte stellen **keine Rechtsberatung** dar und ersetzen nicht die Beratung durch einen qualifizierten Rechtsanwalt oder eine andere rechtlich befugte Person.

📋 Diese Inhalte dienen ausschließlich der **allgemeinen Information und Weiterbildung**.

🏛️ Für rechtlich verbindliche Auskünfte wenden Sie sich bitte an einen **zugelassenen Rechtsanwalt**.

Warum Datenschutz?

Datenschutz ist weit mehr als eine gesetzliche Vorgabe; er ist das Fundament der **digitalen Selbstbestimmung**. Er ermöglicht es jedem Einzelnen, selbst zu entscheiden, welche persönlichen Daten wann, wo und zu welchem Zweck verarbeitet werden dürfen.

In einer Ära, in der KI-Systeme immer mehr Daten sammeln und analysieren, ist dieses **Recht auf Kontrolle essenziell, um Transparenz zu schaffen und Missbrauch vorzubeugen**. Es schützt die individuelle Freiheit und die Privatsphäre in der digitalen Welt.

Rechtsrahmen des Datenschutzes in Deutschland

Das Datenschutzrecht in Deutschland ist ein Zusammenspiel aus europäischem, bundesstaatlichem und landespezifischem Recht. Ihre Anwendbarkeit folgt einer klaren Hierarchie – vom unmittelbar geltenden EU-Recht bis hin zu spezifischen Landes- und Sonderregelungen.



Datenschutz-Grundverordnung (DSGVO)

Das übergeordnete EU-Recht, welches seit Mai 2018 unmittelbar in allen Mitgliedstaaten gilt. Die DSGVO regelt die Grundprinzipien der Datenverarbeitung (Art. 5), die Rechte der betroffenen Personen (Art. 15–22) sowie die Pflichten der Verantwortlichen. Sie lässt jedoch gezielt **Öffnungsklauseln**, die nationale Konkretisierungen ermöglichen – genau hier greifen BDSG und LDSG.



Bundesdatenschutzgesetz (BDSG)

Ergänzt und konkretisiert die DSGVO auf Bundesebene, insbesondere durch die Nutzung nationaler Öffnungsklauseln. Es gilt vorrangig für Bundesbehörden und private Stellen, soweit kein spezielleres Bundesrecht existiert. Das BDSG umfasst außerdem die Umsetzung der **JI-Richtlinie** (Strafverfolgung und Gefahrenabwehr) in §§ 45–84. Es enthält zusätzliche Regelungen zur **Datenverarbeitung im Arbeitsverhältnis**.



Landesdatenschutzgesetze (LDSG)

Jedes der 16 Bundesländer hat ein eigenes LDSG, das für **öffentliche Stellen des jeweiligen Landes** gilt – etwa Behörden, Schulen und Universitäten. Wo Bundesrecht oder die DSGVO Spielraum lassen, regeln die Länder eigenständig. Bestimmte Bereiche wie Rundfunk und Kirchen unterliegen sogar vollständig eigenen Sonderregelungen.

Kapitel 1: Die Grundbegriffe (Art. 4)

Grundlagen und Begriffe



Art. 4 Nr. 1 – Personenbezogene Daten

> "...alle Informationen, die sich auf eine identifizierte oder identifizierbare natürliche Person (...,betroffene Person') beziehen; als identifizierbar wird eine natürliche Person angesehen, die direkt oder indirekt, insbesondere mittels Zuordnung zu einer Kennung wie einem Namen, zu einer Kennnummer, zu **Standortdaten**, zu einer **Online-Kennung** oder zu einem oder mehreren besonderen Merkmalen ... identifiziert werden kann"

Für KI wichtig: Auch IP-Adressen, Cookie-IDs und Standortdaten zählen dazu.

Anonyme Daten fallen **nicht** unter die DSGVO.

Art. 4 Nr. 2 – Verarbeitung

> "...jeden mit oder ohne Hilfe automatisierter Verfahren ausgeführten Vorgang ... wie das **Erheben**, das Erfassen, die Organisation, das Ordnen, die **Speicherung**, die Anpassung oder Veränderung, das Auslesen, das Abfragen, die **Verwendung**, die Offenlegung durch Übermittlung ... die Einschränkung, das **Löschen** oder die Vernichtung"

Kernaussage: Fast alles, was ein KI-Tool mit Daten tut, ist "Verarbeitung" im Sinne der DSGVO.

Art. 4 Nr. 4 – Profiling

> "...jede Art der automatisierten Verarbeitung personenbezogener Daten, die darin besteht, dass diese ... verwendet werden, um bestimmte persönliche Aspekte ... zu **bewerten**, insbesondere um Aspekte bezüglich Arbeitsleistung, wirtschaftliche Lage, Gesundheit, persönliche Vorlieben, Interessen, Zuverlässigkeit, Verhalten, Aufenthaltsort oder Ortswechsel ... zu **analysieren oder vorherzusagen**"

Für KI zentral: Lead-Scoring, Bewerber-Ranking, Verhaltensprognosen — das alles ist Profiling.

Art. 4 Nr. 5 – Pseudonymisierung

> "...die Verarbeitung ... in einer Weise, dass die personenbezogenen Daten **ohne Hinzuziehung zusätzlicher Informationen nicht mehr** einer spezifischen betroffenen Person zugeordnet werden können, sofern diese zusätzlichen Informationen **gesondert** aufbewahrt werden..."

Merke: Pseudonymisiert ≠ anonym. Pseudonyme Daten bleiben personenbezogen — aber das Risiko sinkt.

Art. 4 Nr. 7 & 8 – Die zwei Rollen

Verantwortlicher (Nr. 7):

"...die ... Person ... Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die **Zwecke und Mittel** der Verarbeitung ... entscheidet"

Auftragsverarbeiter (Nr. 8):

"...eine ... Stelle, die personenbezogene Daten **im Auftrag** des Verantwortlichen verarbeitet"





Kapitel 2: Die Grundsätze (Art. 5)

Dein Prüfraster für jede KI-Automatisierung.

Art. 5 Abs. 1 – Die 6 Grundsätze

Personenbezogene Daten müssen:

1	**Rechtmäßigkeit, Treu und Glauben, Transparenz** nachvollziehbar verarbeitet
2	**Zweckbindung** nur für festgelegte, eindeutige Zwecke
3	**Datenminimierung** "auf das notwendige Maß beschränkt"
4	**Richtigkeit** sachlich richtig, aktuell
5	**Speicherbegrenzung** nicht länger als nötig
6	**Integrität & Vertraulichkeit** angemessen gesichert

Art. 5 Abs. 2 — Rechenschaftspflicht

> "Der Verantwortliche ist für die Einhaltung des Absatzes 1 verantwortlich und **muss dessen Einhaltung nachweisen können** (‚Rechenschaftspflicht')."

Übersetzt: Es reicht nicht, sich an die Regeln zu halten — du musst es auch **belegen** können.

Für KI heißt das: dokumentieren, welche Daten warum in welches Tool fließen.

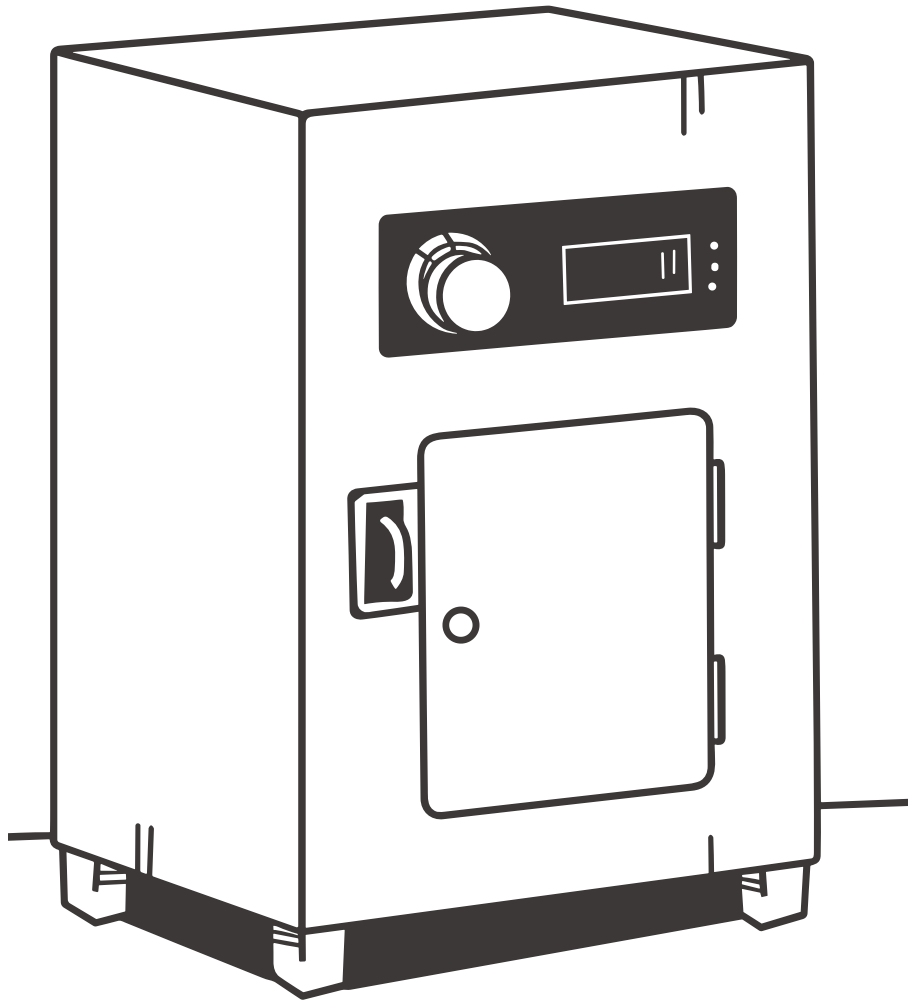
Zwei Grundsätze, die bei KI am häufigsten reißen

Datenminimierung (c)

"Braucht die KI wirklich alle Felder — oder reichen drei statt zwölf?"

Zweckbindung (b)

"Kundendaten für den Vertrag ≠ Kundendaten fürs KI-Training."



Praxisbeispiel: Der „schlanke" Workflow

⚠️ Vorher

Kompletter Kundendatensatz wird in die KI gegeben


```
{
  "vorname": "Maria",
  "nachname": "Müller",
  "email": "maria@example.com",
  "telefon": "+49 151 12345678",
  "geburtsdatum": "1985-03-12",
  "adresse": "Musterstr. 4, 10115 Berlin",
  "iban": "DE89 3704 0044 0532 0130 00",
  "kreditkarte": "4111 1111 1111 1111",
  "ip_adresse": "192.168.1.42",
  "kaufhistorie": ["Produkt A", "Produkt B"],
  "newsletter": true,
  "interne_notizen": "VIP-Kunde seit 2019"
}
```


✓ Nachher

Nur die nötigen Felder für die Versandbestätigung


```
{
  "vorname": "Maria",
  "nachname": "Müller",
  "email": "maria@example.com",
  "adresse": "Musterstr. 4, 10115 Berlin"
}
```


Weniger Daten = weniger Risiko = gelebte Datenminimierung (Art. 5 Abs. 1 c).



Kapitel 3: Rechtmäßigkeit (Art. 6)

Ohne Rechtsgrundlage keine Verarbeitung.

Art. 6 Abs. 1 – Die 6 Rechtsgrundlagen

"Die Verarbeitung ist nur rechtmäßig, wenn mindestens eine der nachstehenden Bedingungen erfüllt ist:"

a) Einwilligung

Einwilligung der betroffenen Person

z.B. Newsletter-Anmeldung mit Opt-in-Checkbox, Cookie-Banner mit aktiver Zustimmung

b) Vertrag

Erfüllung eines **Vertrags** / vorvertragliche Maßnahmen

z.B. Lieferadresse speichern beim Online-Kauf, Rechnungsdaten für Auftragsabwicklung

c) Rechtliche Verpflichtung

Erfüllung einer **rechtlichen Verpflichtung**

z.B. Lohnsteuerunterlagen 6 Jahre aufbewahren (§ 41 EStG), Buchführungspflicht nach HGB

d) Lebenswichtige Interessen

Schutz **lebenswichtiger Interessen**

z.B. Weitergabe von Blutgruppe im Notfall, Standortdaten bei Rettungseinsatz

e) Öffentliches Interesse

Aufgabe im **öffentlichen Interesse** / öffentliche Gewalt

z.B. Meldebehörde, Gesundheitsamt bei Infektionskrankheiten, Statistikämter

f) Berechtigte Interessen

Berechtigte Interessen des Verantwortlichen oder Dritter

z.B. Betrugsprävention, IT-Sicherheitsmonitoring, Direktwerbung an Bestandskunden

Art. 6 Abs. 1 f – Berechtigtes Interesse

> "...zur Wahrung der **berechtigten Interessen** des Verantwortlichen oder eines Dritten erforderlich, sofern nicht die Interessen oder Grundrechte und Grundfreiheiten der betroffenen Person ... **überwiegen**, insbesondere dann, wenn es sich bei der betroffenen Person um ein Kind handelt."

Das ist die häufigste Grundlage im Unternehmensalltag — aber sie verlangt immer eine **Abwägung**.

Der 3-Stufen-Test (Interessenabwägung)

1

Berechtigtes Interesse benennen

Was ist das konkrete Interesse des Verantwortlichen? z.B. Betrugsprävention, Direktmarketing, IT-Sicherheit

2

Erforderlichkeit prüfen

Gibt es ein milderes Mittel? Wäre Anonymisierung ausreichend? Ist die Verarbeitung wirklich notwendig?

3

Abwägung durchführen

Überwiegen die Interessen der betroffenen Person? Besonders bei Kindern und sensiblen Daten ist Vorsicht geboten.

Typische Beispiele

✅ Berechtigtes Interesse greift

- Bestandskundenmarketing per Post
- Interne IT-Sicherheitslogs
- Bonitätsprüfung vor Vertragsschluss
- Videoüberwachung Eingangsbereich (mit Hinweisschild)
- Interne Organisation und Verwaltung von Mitarbeitern, etwa Erstellung von Telefonlisten oder Organigrammen für betriebliche Abläufe
- Anzeige von personalisierten Produktempfehlungen für Bestandskunden auf Basis früherer Käufe, mit klarer Transparenz und Widerspruchsmöglichkeit
- Kommunikation mit interessierten Personen (z.B. Rückrufwünsche, Kontaktformularanfragen) und anschließende Nachverfolgung, solange ein fortbestehendes Interesse plausibel ist
- Kundenverwaltung in einem Unternehmen (z.B. Pflege von Kundenstammdaten, Kontaktpersonen, Historien), um laufende Geschäftsbeziehungen effizient zu organisieren

❌ Greift NICHT

- Newsletter und E-Mail-Werbung an Nicht-Kunden (z.B. Double-Opt-In für Marketingmails)
- Einwilligung in nicht notwendige Cookies (Tracking, Marketing, Social-Media-Plugins)
- Weitergabe an Dritte ohne Notwendigkeit
- Profiling von Kindern
- **Automatisierte Entscheidungen** mit erheblichen Auswirkungen (z.B. Scoring, bestimmte Kreditentscheidungen)
- Verarbeitung sensibler Daten (Gesundheit, Religion, politische Meinung, Gewerkschaftszugehörigkeit) nach Art. 9 DSGVO, sofern keine andere spezielle Ausnahme greift.
- Profiling (z.B. „Kundenkonto + personalisierte Angebote auf Basis meines Verhaltens“) über personalisierte Produktempfehlungen hinausgehend (Tracking, Verweildauer, Verknüpfung mit externen Dartenquellen)

Praxisbeispiel: E-Mail-Marketing

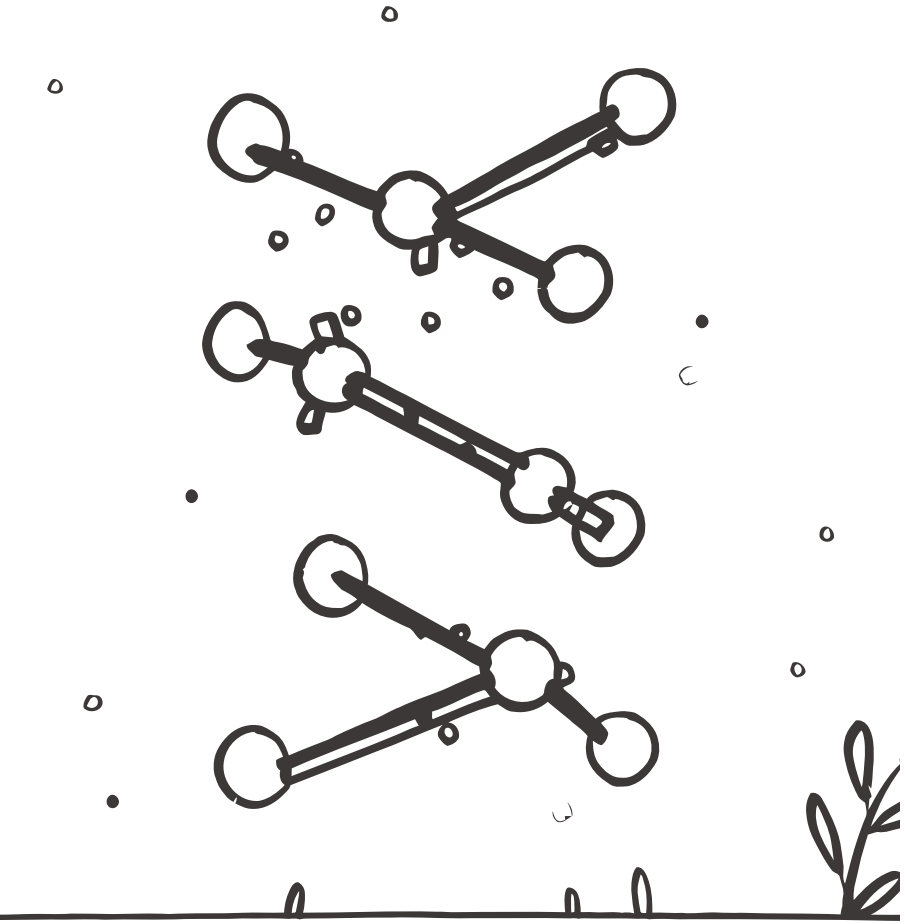
nicht konform:

Bestandsadressen ohne Zustimmung ins KI-Marketing-Tool kippen

konform:

Einwilligung per Double-Opt-In beim Newsletter-Anmelden (Art. 6 Abs. 1 a)

Faustregel: Werbung an Fremde → in der Regel Einwilligung nötig. Außerdem Verstoß gegen § 7 UWG (unzumutbare Belästigung)



Kapitel 4: Einwilligung (Art. 7)

Wenn du dich auf Einwilligung stützt, muss sie sauber sein.

Art. 7 – Bedingungen der Einwilligung

> Abs. 1: "...muss der Verantwortliche **nachweisen können**, dass die betroffene Person ... eingewilligt hat."

> Abs. 3: "Die betroffene Person hat das Recht, ihre Einwilligung **jederzeit zu widerrufen**. ... Der Widerruf ... muss **so einfach wie die Erteilung** der Einwilligung sein."

Merke: Freiwillig, informiert, widerrufbar. Vorangekreuzte Kästchen und Stillschweigen zählen nicht.



Kapitel 5: Besondere Kategorien (Art. 9)

Sensible Daten — hier gelten strengere Regeln.

Art. 9 Abs. 1 – Grundsätzliches Verbot

> "Die Verarbeitung personenbezogener Daten, aus denen die **rassische und ethnische Herkunft, politische Meinungen, religiöse oder weltanschauliche Überzeugungen** oder die **Gewerkschaftszugehörigkeit** hervorgehen, sowie die Verarbeitung von **genetischen Daten, biometrischen Daten** zur eindeutigen Identifizierung ..., **Gesundheitsdaten** oder Daten zum **Sexualleben** ... ist **untersagt**."

Art. 9 Abs. 2 — Die wichtigsten Ausnahmen

Das Verbot gilt u. a. nicht, wenn:

a) Ausdrückliche Einwilligung

ausdrückliche Einwilligung vorliegt

b) Arbeitsrecht

Arbeitsrecht / soziale Sicherheit es erfordert

h) Gesundheitsversorgung

Gesundheitsversorgung durch Fachpersonal

e) Öffentlich gemacht

die Person die Daten selbst öffentlich gemacht hat

Für KI heißt das: Sensible Daten nie einfach so in ein Tool geben — erst Ausnahme prüfen.

Kapitel 6: Transparenz & Betroffenenrechte (Art. 12–15)

Was du den Menschen sagen musst, deren Daten du nutzt.



Art. 13 / 14 — Informationspflichten

Bei der Erhebung musst du u. a. mitteilen:

Wer ist der Verantwortliche?	Zwecke und **Rechtsgrundlage** der Verarbeitung
Empfänger der Daten	Speicherdauer
Bestehen von Betroffenenrechten	**Absicht der Übermittlung in ein Drittland** (Art. 13 Abs. 1 f)

Bei KI-Profiling: auch "aussagekräftige Informationen über die involvierte Logik".

Art. 15 – Auskunftsrecht

> "Die betroffene Person hat das Recht, … eine **Bestätigung** darüber zu verlangen, ob sie betreffende personenbezogene Daten verarbeitet werden; ist dies der Fall, so hat sie ein **Recht auf Auskunft** über diese … Daten…"

Praxisfolge: Du musst jederzeit sagen können, welche Daten eine Person betreffen und wo sie stecken — auch in KI-Systemen.

Die Betroffenenrechte im Überblick (Art. 15–22)

Jede Person hat gegenüber dir bzw. deinem Betrieb das Recht auf:

Art. 15
Auskunft

Art. 16
Berichtigung falscher Daten

Art. 17
Löschung ("Recht auf Vergessenwerden")

Art. 18
Einschränkung der Verarbeitung

Art. 20
Datenübertragbarkeit

Art. 21
Widerspruch (u. a. gegen Direktwerbung)

Art. 22
keine rein automatisierte Einzelentscheidung

Betroffenenanfrage — so reagierst du (Art. 12)

> Abs. 3: "Der Verantwortliche stellt der betroffenen Person Informationen … **unverzüglich, in jedem Fall aber innerhalb eines Monats** nach Eingang des Antrags zur Verfügung."

Praxis-Ablauf:

- Anfrage geht ein (formlos, auch per Mail)
- **Identität prüfen** (Art. 12 Abs. 6)
- Daten zusammenstellen — auch aus KI-Tools
- **Innerhalb eines Monats** antworten (grundsätzlich **unentgeltlich**)

Verlängerung um bis zu 2 Monate möglich — mit Begründung.

Löschkonzept (Art. 5 e + Art. 17)

Die **Speicherbegrenzung** verlangt, dass du Löschfristen festlegst.

Ein Löschkonzept ordnet jeder Datenart eine Frist zu — Beispiele:

Abgelehnte Bewerbungen

ca. 6 Monate

Newsletter-Daten

bis zum Widerruf

Rechnungen

10 Jahre (steuerrechtlich)

⚠ ⚠️ Konkrete Fristen ergeben sich aus Steuer- und Handelsrecht — im Einzelfall prüfen.



Kapitel 7: Automatisierte Entscheidungen (Art. 22)

Das Herzstück für KI.



Art. 22 Abs. 1 — Automatisierte Entscheidungen & Profiling

> "Die betroffene Person hat das Recht, **nicht** einer ausschließlich auf einer **automatisierten Verarbeitung** — einschließlich Profiling — beruhenden **Entscheidung unterworfen zu werden**, die ihr gegenüber **rechtliche Wirkung** entfaltet oder sie in ähnlicher Weise erheblich beeinträchtigt."

Beispiele: automatische Kreditablehnung, KI-Bewerber-Aussortierung, automatisierte Preis-/Angebotsentscheidungen.

Es gelten darüber hinaus erweiterte Informationspflichten an den Betroffenen (Art. 22 Abs. 2 f).

Art. 22 Abs. 2 & 3 — Ausnahmen & Schutz

Erlaubt ist die automatisierte Entscheidung u. a., wenn sie (Abs. 2):

für einen **Vertrag erforderlich** ist

gesetzlich zugelassen ist

auf **ausdrücklicher Einwilligung** beruht

Abs. 3: Dann müssen mindestens **das Recht auf Eingreifen einer Person**, auf Darlegung des Standpunkts und auf **Anfechtung** der Entscheidung gewahrt sein.



Praxisbeispiel: KI-Bewerbermanagement

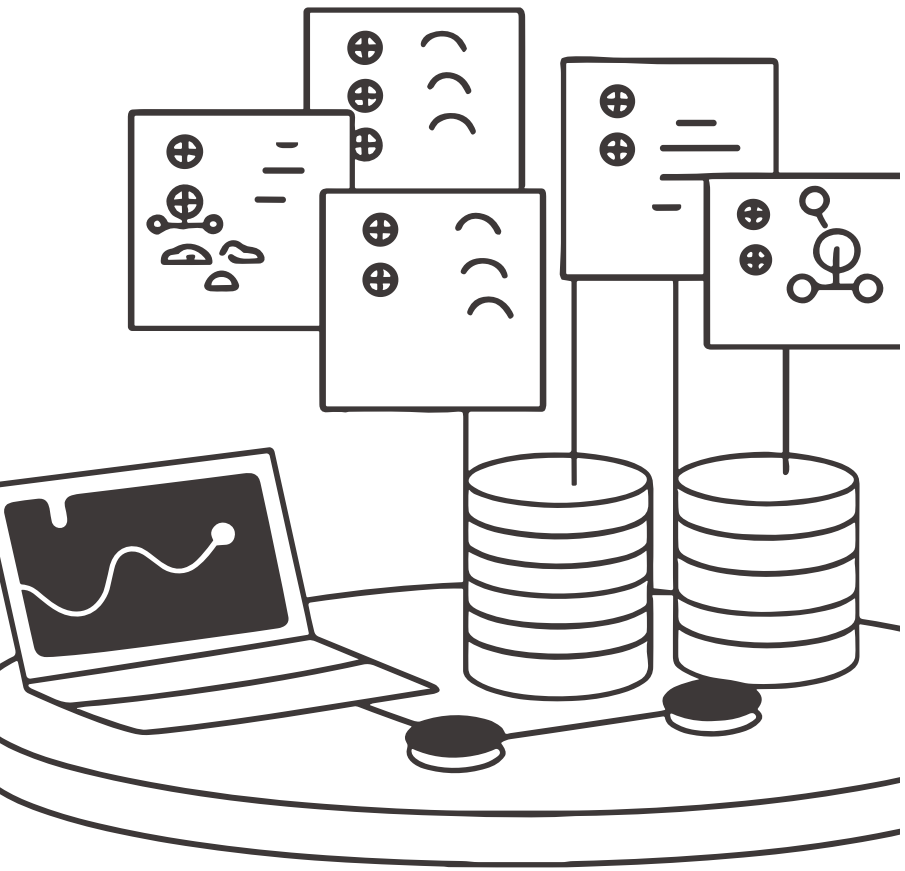
KI sortiert und bewertet Bewerbungen.

Profiling nach Art. 4 Nr. 4 + Entscheidung nach Art. 22

Pflicht: **menschliche Letztentscheidung**

Risiko: Diskriminierung durch verzerrte Trainingsdaten

Transparenz gegenüber Bewerbern (Art. 13)



Kapitel 8: Pflichten des Verantwortlichen (Art. 25, 28, 30)

Die organisatorische Grundausstattung.

Art. 25 – Privacy by Design & Default

> Abs. 1: "...trifft der Verantwortliche ... geeignete technische und organisatorische Maßnahmen — wie z. B. **Pseudonymisierung** —, die dafür ausgelegt sind, die **Datenschutzgrundsätze … wirksam umzusetzen**..."

> Abs. 2: "...dass durch **Voreinstellung** grundsätzlich nur personenbezogene Daten ... verarbeitet werden, deren Verarbeitung für den ... Zweck erforderlich ist."

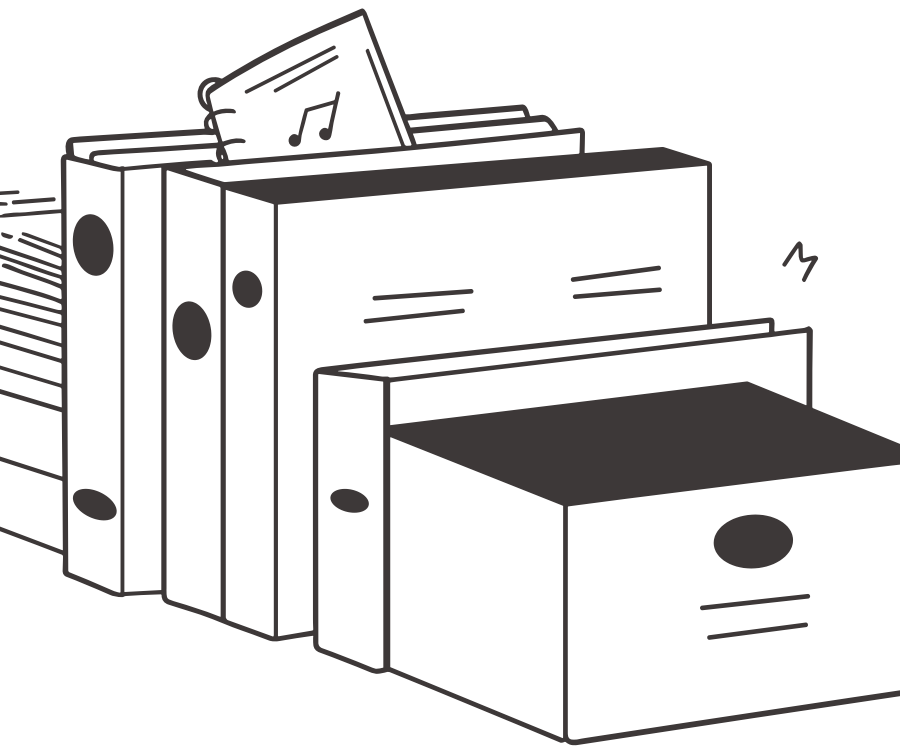
Für KI: Datenschutz schon bei der **Tool-Auswahl** mitdenken, nicht nachträglich.

Art. 28 – Auftragsverarbeiter (AVV)

> Abs. 3: "Die Verarbeitung durch einen Auftragsverarbeiter erfolgt auf der Grundlage eines **Vertrags** … der bzw. das den Auftragsverarbeiter in Bezug auf den Verantwortlichen bindet und in dem **Gegenstand und Dauer** der Verarbeitung, **Art und Zweck**, die Art der Daten … festgelegt sind…"

Klartext: Jedes externe KI-Tool, das Daten verarbeitet, braucht einen AVV.

⊗ Faustregel: Kein AVV = kein Einsatz.



Art. 30 – Verzeichnis von Verarbeitungstätigkeiten

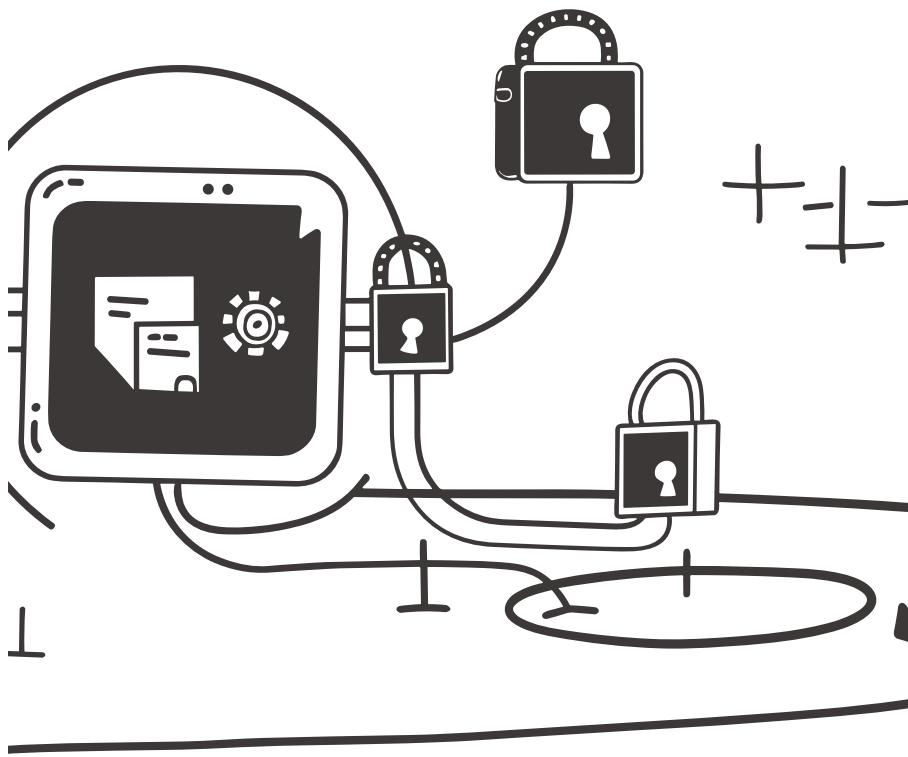
> Abs. 1: "Jeder Verantwortliche … **führt ein Verzeichnis** aller Verarbeitungstätigkeiten…"

Abs. 5: Erleichterung für Betriebe mit **weniger als 250 Mitarbeitern** — aber **nicht**, wenn die Verarbeitung ein Risiko birgt, **nicht nur gelegentlich** erfolgt oder **sensible Daten** betrifft.

Als Angestellte:r: wissen, dass es existiert. **Als Selbstständige:r:** selbst anlegen.

Kapitel 9: Sicherheit & Datenpannen (Art. 32–34)

Wenn etwas schiefgeht.



Art. 32 — Sicherheit der Verarbeitung

> Abs. 1: "...treffen der Verantwortliche und der Auftragsverarbeiter geeignete technische und organisatorische Maßnahmen, um ein dem Risiko angemessenes Schutzniveau zu gewährleisten; diese Maßnahmen schließen ... ein: a) die **Pseudonymisierung und Verschlüsselung**..."

Praktisch: Zugriffsrechte, Verschlüsselung, regelmäßige Überprüfung — auch bei KI-Tools.

Exkurs: Technische & Organisatorische Maßnahmen (TOM)

TOM sind der **Kern von Art. 32** — und tauchen auch in Art. 24, 25, 28 und 30 auf.

Technisch

= setzt an Technik/System an

Organisatorisch

= setzt an Abläufen/Menschen an

Beides zusammen soll das "dem Risiko angemessene Schutzniveau" (Art. 32 Abs. 1) herstellen.

TOM – konkrete Beispiele

Technisch:

- Verschlüsselung (Festplatte, Transport/TLS)
- Zugriffskontrolle: Passwörter, 2-Faktor
- Pseudonymisierung
- Backups & Firewalls, Virenschutz
- automatische Bildschirmsperre

Organisatorisch:

- Berechtigungskonzept (wer darf was?)
- Mitarbeiterschulungen
- Verpflichtung auf Vertraulichkeit
- Clean-Desk-Policy
- Löschkonzept, Notfallplan für Pannen

TOM bei KI-Tools ganz konkret

Eigene Accounts statt geteilter Logins

Keine Klarnamen von Kunden im Prompt (vorher pseudonymisieren)

Tool mit **EU-Serverstandort** bevorzugen

Prüfen: Werden Eingaben zum **Training** genutzt? → abschalten

Zugriff auf das Nötigste beschränken

TOM sind kein einmaliges Projekt — Art. 32 verlangt regelmäßige Überprüfung.

Art. 33 Abs. 1 — Die 72-Stunden-Regel

> "Im Falle einer **Verletzung des Schutzes personenbezogener Daten** meldet der Verantwortliche **unverzüglich und möglichst binnen 72 Stunden**, nachdem ihm die Verletzung bekannt wurde, diese der … zuständigen Aufsichtsbehörde, es sei denn, dass die Verletzung … voraussichtlich **nicht zu einem Risiko** … führt."

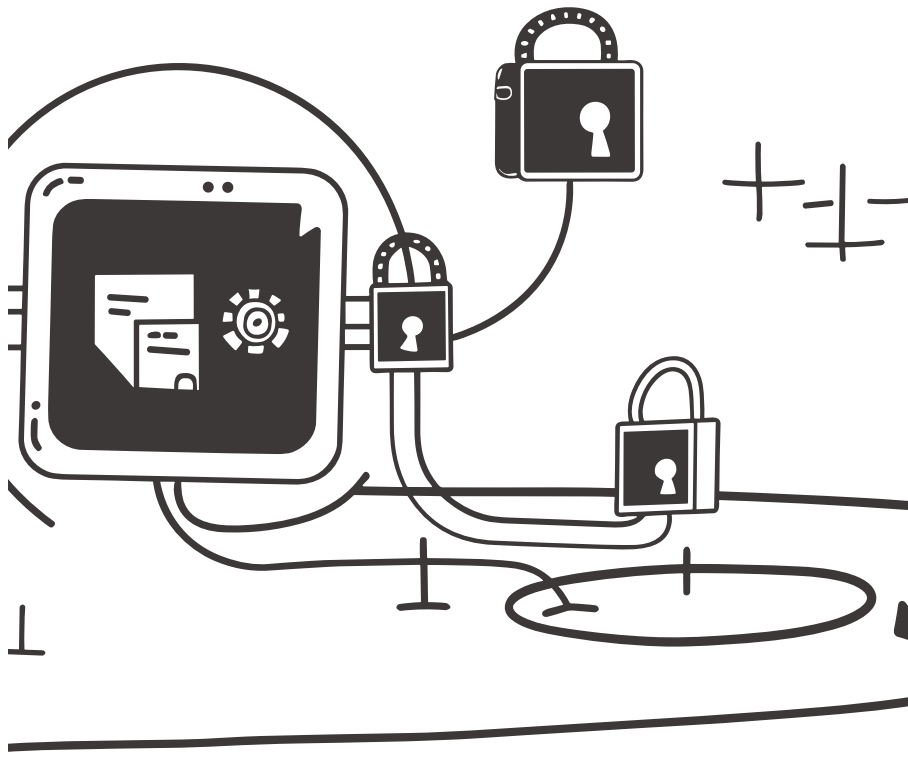
Als Angestellte:r ist dein wichtigster Beitrag: **sofort melden**, nicht selbst vertuschen.



Art. 34 – Betroffene benachrichtigen

> Abs. 1: "Hat die Verletzung ... voraussichtlich ein **hohes Risiko** für die ... Rechte und Freiheiten natürlicher Personen zur Folge, so **benachrichtigt der Verantwortliche die betroffene Person unverzüglich**..."

Ausnahme (Abs. 3): z. B. wenn die Daten verschlüsselt und dadurch unzugänglich waren.





Kapitel 10: Folgenabschätzung & DSB (Art. 35, 37)

Wann Vorabprüfung und Beauftragte:r nötig sind.



Art. 35 – Datenschutz-Folgenabschätzung

Abs. 1: "Hat eine Form der Verarbeitung, insbesondere bei Verwendung **neuer Technologien**, ... voraussichtlich ein **hohes Risiko** ... zur Folge, so führt der Verantwortliche **vorab** eine ... Folgenabschätzung durch."

Pflicht insbesondere (Abs. 3) bei:

Profiling

systematischem **Profiling** mit erheblicher Wirkung

Sensible Daten

umfangreicher Verarbeitung **sensibler Daten**

Überwachung

umfangreicher **Überwachung** öffentlicher Bereiche

Art. 37 — Datenschutzbeauftragte:r

Benennung ist Pflicht u. a., wenn (Abs. 1):

a)

Behörde / öffentliche Stelle

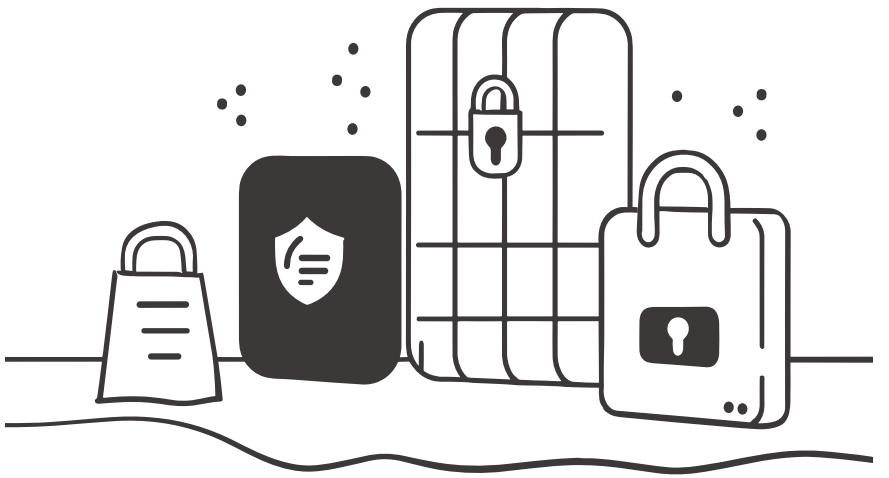
b)

Kerntätigkeit = umfangreiche, **regelmäßige und systematische Überwachung** von Personen

c)

Kerntätigkeit = umfangreiche Verarbeitung **sensibler Daten**

Zusätzlich können **nationale Regeln** greifen (in DE z. B. ab einer bestimmten Mitarbeiterzahl — Stand prüfen).



Kapitel II: Datenübermittlung in Drittländer (Art. 44–49)

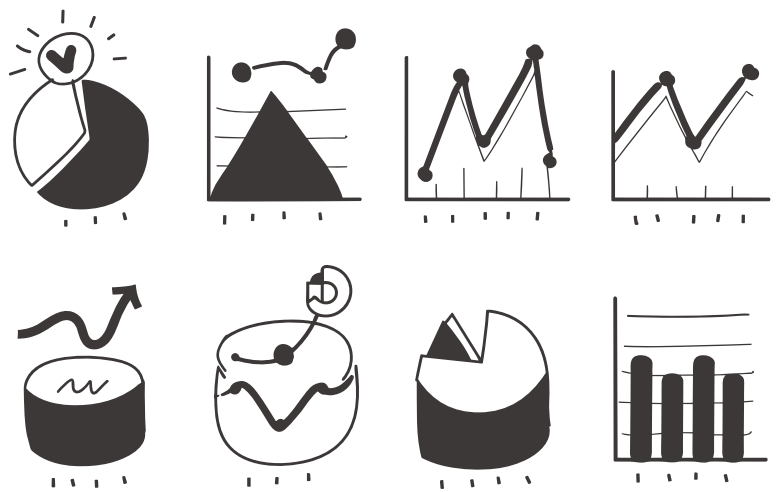
Der Knackpunkt bei US-KI-Tools.



Art. 44 – Das Grundprinzip

> "Jedwede Übermittlung personenbezogener Daten … an ein **Drittland** oder eine internationale Organisation … ist nur zulässig, wenn der Verantwortliche und der Auftragsverarbeiter die in diesem Kapitel niedergelegten Bedingungen einhalten … Alle Bestimmungen dieses Kapitels sind anzuwenden, um sicherzustellen, dass das … **Schutzniveau … nicht untergraben wird**."

Drittland = Land außerhalb der EU/EWR. Also z. B. USA.



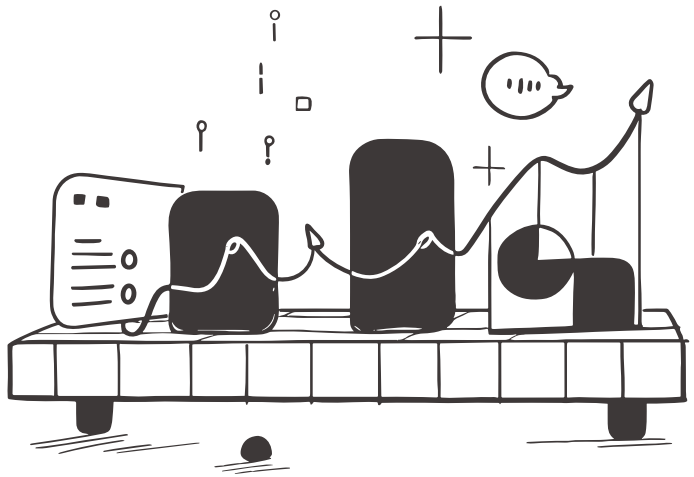
Art. 45 – Angemessenheitsbeschluss

> Abs. 1: "Eine Übermittlung ... darf vorgenommen werden, wenn die Kommission beschlossen hat, dass das betreffende Drittland ... ein **angemessenes Schutzniveau** bietet. Eine solche Datenübermittlung bedarf **keiner besonderen Genehmigung**."

Praxis: Für die USA gibt es das **EU-US Data Privacy Framework (DPF)**.

⚠ ⚠️ Nur zertifizierte US-Anbieter fallen darunter — und der Status kann sich ändern. **Aktuell prüfen!**

Wenn keine DPF-Zertifizierung bei US-Anbieter, dann auf SCC zurückgreifen.



Art. 46 – Geeignete Garantien (Überblick)

> Abs. 1: "Falls **kein** Beschluss nach Artikel 45 … vorliegt, darf … nur übermitteln, sofern der Verantwortliche … **geeignete Garantien** vorgesehen hat und … **durchsetzbare Rechte und wirksame Rechtsbehelfe** zur Verfügung stehen."

Diese Garantien können bestehen in (Abs. 2):

a)

einem rechtlich bindenden und durchsetzbaren Dokument zwischen den Behörden oder öffentlichen Stellen

b)

verbindlichen internen Datenschutzvorschriften (BCR, Art. 47)

c) / d)

Standarddatenschutzklauseln (SCCs)

e)

genehmigten Verhaltensregeln

f)

genehmigtem Zertifizierungsmechanismus

SCCs im Detail (1) – Was sind Standardvertragsklauseln?

> Art. 46 Abs. 2 c: "**Standarddatenschutzklauseln**, die von der Kommission ... erlassen werden"

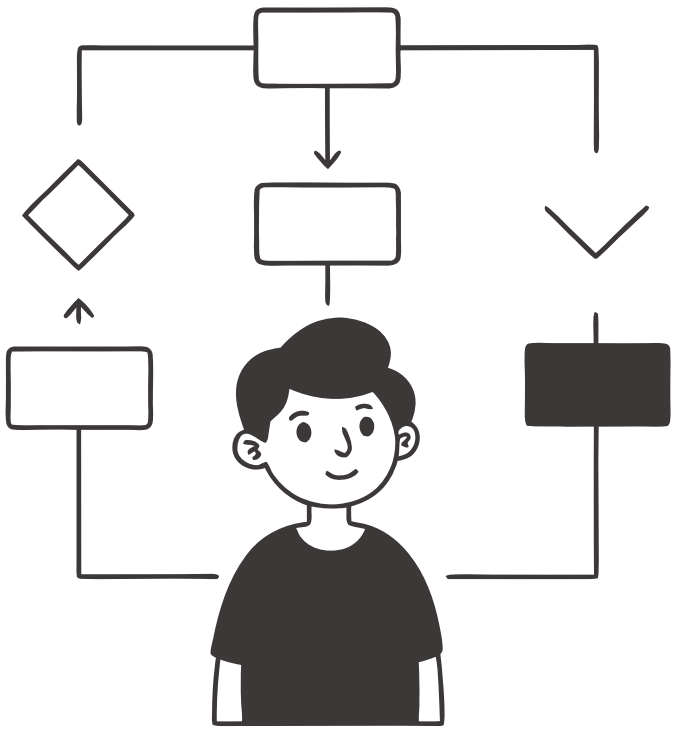
Von der **EU-Kommission** vorformulierte Vertragsbausteine

Werden zwischen **Datenexporteur** (du/dein Betrieb) und **Datenimporteur** (US-Anbieter) geschlossen

Keine behördliche Einzelgenehmigung nötig

Das **häufigste** Instrument in der Praxis, wenn kein DPF greift





SCCs im Detail (2) – So nutzt du sie konkret

Ablauf bei einem US-KI-Tool ohne DPF-Zertifizierung:

01

Prüfen, ob der Anbieter **SCCs** anbietet (meist im Auftragsverarbeitungs-/Datenschutz-Addendum)

02

Passendes **Modul** wählen (Verantwortlicher→Auftragsverarbeiter ist der Normalfall)

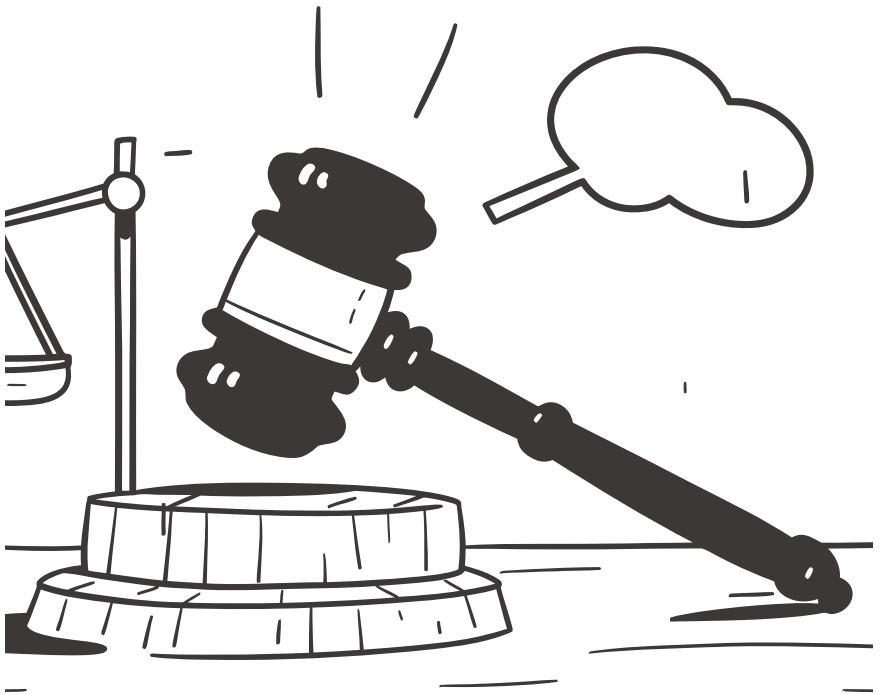
03

SCCs als Teil des **AVV (Art. 28)** abschließen

04

Die im Vertrag genannten Pflichten auch **tatsächlich umsetzen**

Seriöse Anbieter (Cloud, KI) stellen SCCs standardmäßig bereit — du musst sie nur aktiv annehmen.



SCCs im Detail (3) — SCCs allein reichen oft nicht

Aus der Rechtsprechung des EuGH ("Schrems II"):

> SCCs müssen durch eine **Risikoprüfung des Ziellands** ergänzt werden (Transfer Impact Assessment)

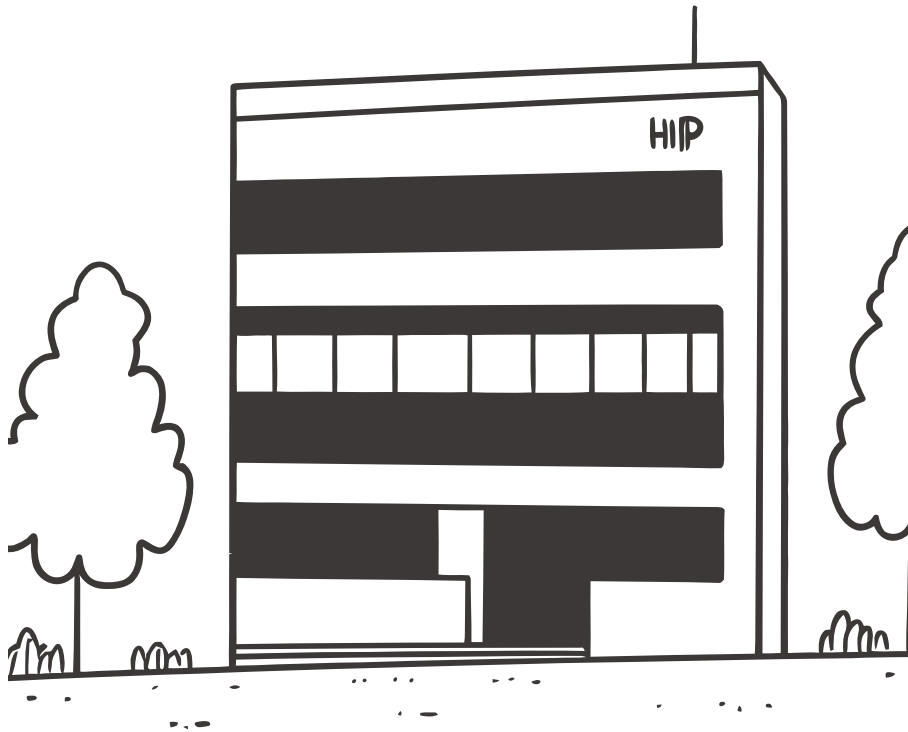
> Ergibt die Prüfung Lücken, sind **zusätzliche Maßnahmen** nötig — z. B. **Verschlüsselung** oder Pseudonymisierung

⚠ ⚠️ Dieser Punkt beruht auf **EuGH-Rechtsprechung**, nicht direkt auf dem Verordnungstext, und entwickelt sich weiter. **Aktuellen Stand prüfen.**

Art. 47 – Verbindliche interne Datenschutzvorschriften (BCR)

> Abs. 1: "Die zuständige Aufsichtsbehörde **genehmigt** ... **verbindliche interne Datenschutzvorschriften**, sofern diese ... a) **rechtlich bindend** sind, für alle betreffenden Mitglieder der Unternehmensgruppe ... gelten ... b) den betroffenen Personen ausdrücklich **durchsetzbare Rechte** ... übertragen..."

Für wen relevant? Vor allem **Konzerne** mit vielen Standorten. Für kleine Betriebe sind SCCs praktischer.



Art. 49 – Ausnahmen für bestimmte Fälle

Wenn weder Angemessenheitsbeschluss noch Garantien vorliegen, ist die Übermittlung nur zulässig, wenn z. B.:

a)

die Person **ausdrücklich einwilligt** (nach Risiko-Aufklärung)

b)

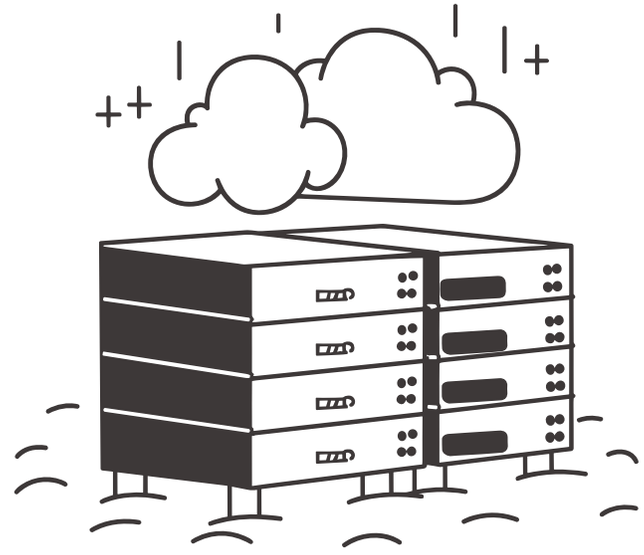
sie zur **Vertragserfüllung** erforderlich ist

d)

wichtige Gründe des **öffentlichen Interesses** vorliegen

e)

sie zur **Rechtsverteidigung** erforderlich ist



Wichtig: Das sind **eng auszulegende Einzelfall-Ausnahmen**, kein Dauer-Freifahrtschein.

Praxisbeispiel: Kundendaten in ChatGPT?

Entscheidungsweg:

Personenbezug? → wenn nein: unkritisch

Rechtsgrundlage (Art. 6)?

Sensible Daten (Art. 9)? → besonders vorsichtig

Drittland? → DPF-Zertifizierung ODER SCCs (Art. 46) im AVV

Datenminimierung — so wenig wie möglich hineingeben

Sicherste Variante: personenbezogene Daten vor Eingabe **anonymisieren**.

Kapitel 12: Bußgelder (Art. 83)

Warum sich sauberes Arbeiten lohnt.



Art. 83 — Zwei Bußgeld-Stufen

Abs. 4 — Bis zu 10 Mio. EUR / 2 %

"...Geldbußen von bis zu **10 000 000 EUR** oder ... bis zu **2 %** seines ... Jahresumsatzes..." (u. a. Verstöße gegen Art. 25, 28, 30, 35 — die **organisatorischen** Pflichten)

Abs. 5 — Bis zu 20 Mio. EUR / 4 %

"...Geldbußen von bis zu **20 000 000 EUR** oder ... bis zu **4 %** seines ... Jahresumsatzes..." (u. a. Verstöße gegen die **Grundsätze** Art. 5, 6, 9 und die **Betroffenenrechte** Art. 12–22)

"...je nachdem, welcher der Beträge höher ist."



Kapitel 13: Die Arbeitsdokumente im Datenschutz

In der Praxis lebt Datenschutz von Dokumenten. So sehen sie aus.

Verarbeitungsverzeichnis — die Felder (Art. 30)

Für jede Verarbeitung hältst du fest:

Name der Verarbeitung	Zweck & Rechtsgrundlage
Kategorien betroffener Personen	Kategorien der Daten
Empfänger	Drittlandübermittlung?
Löschfrist	allgemeine TOM

Verarbeitungsverzeichnis — ausgefülltes Beispiel

Feld	Beispiel-Eintrag
Verarbeitung	Newsletter-Versand
Zweck	Kundenbindung / Marketing
Rechtsgrundlage	Einwilligung (Art. 6 Abs. 1 a)
Betroffene	Newsletter-Abonnenten
Datenarten	E-Mail, Name, Öffnungsrate
Empfänger	E-Mail-Tool (Auftragsverarbeiter)
Drittland	USA — SCCs (Art. 46)
Löschfrist	bis Widerruf
TOM	Zugriffsschutz, Verschlüsselung

Datenschutz-Folgenabschätzung – die Struktur (Art. 35 Abs. 7)

Eine DSFA enthält mindestens:

a)

systematische Beschreibung der Verarbeitung + Zwecke

b)

Bewertung von **Notwendigkeit & Verhältnismäßigkeit**

c)

Bewertung der **Risiken** für die Betroffenen

d)

geplante **Abhilfemaßnahmen** und Garantien



Risikoabschätzung — Mini-Beispiel: KI-Bewerber-Scoring

Schritt	Inhalt
Verarbeitung	Automatische Vorbewertung von Bewerbungen
Risiken	Diskriminierung, falsche Ablehnung, Intransparenz
Wahrscheinlichkeit	mittel
Schwere	hoch
Maßnahmen	menschliche Letztentscheidung, Bias-Tests, Transparenz, Datenminimierung
Ergebnis	mittel - Restrisiko vertretbar

Risiko einstufen – einfache Matrix

Wahrscheinlichkeit → Schwere ↓	gering	mittel	hoch
gering	niedrig	niedrig	mittel
mittel	niedrig	mittel	hoch
hoch	mittel	hoch	**sehr hoch**

⚠ "Hoch" oder "sehr hoch" → Folgenabschätzung und ggf. Konsultation der Behörde.

Weitere Dokumente, die du kennen solltest

AVV (Art. 28)

Vertrag mit jedem Tool-Anbieter

Datenschutzhinweise (Art. 13/14)

für Website & Kunden

Einwilligungserklärung (Art. 7)

nachweisbar dokumentiert

TOM-Dokumentation (Art. 32)

Liste deiner Schutzmaßnahmen

Datenpannen-Register (Art. 33 Abs. 5)

jede Panne festhalten

Löschkonzept (Art. 17)

Fristen pro Datenart

Schulungsnachweise

wer wurde wann geschult?

Datenschutzhinweise – Mindestinhalt (Art. 13)

Das Dokument, das jeder Kunde sehen darf. Es nennt:

1

Wer ist verantwortlich?

(Name, Kontakt)

2

Welche Zwecke & Rechtsgrundlagen?

3

Wer bekommt die Daten (Empfänger)?

4

Drittlandübermittlung?

5

Speicherdauer

6

Die Betroffenenrechte (Art. 15–22)

7

Beschwerderecht bei der Aufsichtsbehörde

Kapitel 14: Zusammenfassung & Werkzeuge

Was du mitnimmst.



Die DSGVO-KI-Ampel

Schnelles Entscheidungsschema für den Alltag:

🟢 Grün

Anonyme Daten, klare Rechtsgrundlage, AVV vorhanden → los

🟡 Gelb

Personenbezug, aber offene Punkte → erst klären

🔴 Rot

Sensible Daten (Art. 9), Profiling (Art. 22), US-Tool ohne DPF/SCCs → stopp & prüfen

Checkliste: Neues KI-Tool einführen

1. Werden personenbezogene Daten verarbeitet? (Art. 4)
2. Gibt es eine Rechtsgrundlage? (Art. 6)
3. Sind sensible Daten dabei? (Art. 9)
4. Ist ein AVV vorhanden? (Art. 28)
5. Drittlandübermittlung – DPF oder SCCs? (Art. 45/46)
6. Ist eine Folgenabschätzung nötig? (Art. 35)
7. Sind angemessene TOM getroffen? (Art. 32)
8. Datenminimierung geprüft? (Art. 5)

Die 10 wichtigsten Take-aways

1. Der Verantwortliche entscheidet — nicht das Tool (Art. 4)
2. Kein Personenbezug = kein Problem → Anonymisierung nutzen
3. Immer eine Rechtsgrundlage prüfen (Art. 6)
4. Datenminimierung ist dein bester Freund (Art. 5)
5. Sensible Daten sind grundsätzlich verboten (Art. 9)
6. Kein KI-Tool ohne AVV (Art. 28)
7. Drittland braucht DPF oder SCCs (Art. 45/46)
8. SCCs oft + Zusatzmaßnahmen (Schrems II)
9. 72-Stunden-Regel bei Pannen (Art. 33)
10. Dokumentieren = Rechenschaftspflicht (Art. 5 Abs. 2)



Handlungsempfehlungen

Wenn du angestellt bist:

- Risiken erkennen und melden
- Nie eigenmächtig sensible Daten in KI-Tools geben
- Datenschutzbeauftragten / Chef einbeziehen

Wenn du selbstständig bist:

- Verarbeitungsverzeichnis anlegen (Art. 30)
- AVVs + ggf. SCCs mit allen Tools abschließen (Art. 28/46)
- DSGVO-KI-Ampel zur Routine machen

Langdock Trust Center



trust.langdock.com

Langdock GmbH Trust Center

Langdock is the enterprise-ready platform to roll out AI to all of your employees. Plus, enabling your developers to build and deploy the most custom AI workflows.